

TVRM: A Tri-Vector Risk Model for Privacy-Adjusted Vulnerability Prioritization in Integrated Security and Privacy Governance

Tejashwini S Uranakar

Department of Information Science & Engineering
BMS Institute of Technology & Management
Bengaluru, India
tejashwinisuranakar@ieee.org

Arun Kumar B R

Department of Information Science & Engineering
BMS Institute of Technology & Management
Bengaluru, India
arunkumarbr@bmsit.in

Abstract—Vulnerability prioritization based on traditional Common Vulnerability Scoring System (CVSS) measurements takes place independently of the sensitivity of the underlying data and the efficacy of defenses employed, creating huge remediation backlogs and wasted resources. In this paper, a novel approach called the Tri-Vector Risk Model (TVRM) is proposed along with its key mathematical tool for risk prioritization and computation—the Privacy Adjusted Risk Score (PARS), which integrates CVSS software vulnerability measurements, Privacy Impact Ratings (PIR), and Control Effectiveness Scores (CES). Tested on a real-life telehealth infrastructure layer with 1,245 monitored assets, the PARS methodology eliminates priority inconsistencies by considering the dynamic context of enterprise assets. The implementation of PARS results in a quantifiable 66.7% reduction in urgent alerts and shifts the critical backlog from 42% down to 14%, alongside a reduction of critical vulnerability resolution timeframes from 14 days to under 24 hours.

Index Terms—VAPT, CVSS, Privacy Risk Scoring, Internet of Medical Things (IoMT), Governance, Risk, and Compliance (GRC), Risk Prioritization, Vulnerability Management.

I. INTRODUCTION AND PROBLEM STATEMENT

A. Motivation: The Governance Context Gap

Since the standard adoption of dynamic evaluation practices, CVSS scoring has been used in cybersecurity as the deterministic language for risk calculation. Remediation backlogs resulting from Vulnerability Assessment and Penetration Testing (VAPT) engagements are scheduled based on numerical priority alone. This approach is no longer valid in today's data-centric enterprises where Internet of Medical Things (IoMT) or healthcare networks are commonplace and where severity metrics remain fully independent of the underlying data context [1], [2]. The outcome is significant engineering inefficiencies; for example, rapid patch remediation may be scheduled for a severe buffer overflow in a legacy isolated internal test system, while a medium technical vulnerability such as Broken Object Level Authorization (BOLA) in an API gateway protecting live genomic datasets goes untriaged. Traditional risk matrices fail to account for: (a) Privacy Classification Expansion Factors associated with data processed by

the assets layer; and (b) Real-time Health Status of adjacent compensating controls.

B. Research Gap

Modern literature underscores considerable expansion in terms of intelligent and interconnected architecture in the health care system, focusing on the most important vulnerabilities within these systems [9], [10]. However, the current models do not consider privacy engineering and security activities as related processes. While the qualitative PIA models consider compliance aspects [13], they do not have any automation capabilities that can affect the technical backlog. On the other hand, technical vulnerability measures do not consider data sensitivity, considering all the backend hosts as equal nodes. To the best of operational knowledge at this current time, the model suggested in this research is the first one in which CVSS software vulnerabilities, PIR and CES are mathematically integrated into a unified model [15].

C. Research Objectives

The four main structural goals for the investigation are as follows: (1) Derive an integrated and normalized multi-vector mathematical equation (TVRM/PARS), complete with edge case clamps to ensure no boundary truncation; (2) Build a replicable data pipeline prototype capable of receiving and correlating data from scanner telematics data logs, asset inventories, and governance metrics; (3) Test the behavior of the model on a local telehealth system dataset with regard to inverted rank profiles compared to standard Risk-Based Vulnerability Management (RBVM); and (4) Validate the bounding features using sensitivity multivariable equations and Monte Carlo simulations.

II. BACKGROUND AND RELATED WORK

A. Security and Privacy Complexities in Modern IoT and IoMT

Networked IoT infrastructures have significantly increased the attack surfaces of enterprises, posing new threats to infrastructure security [1]. For IoMT infrastructures, the situation is further exacerbated due to the mandatory regulatory

policies concerning PHI and bio-streaming channels as per HIPAA and GDPR guidelines [10], [11]. According to recent survey reports, periodic and manual approaches for assessing risks fail to handle dynamic data exposure problems in these environments [2], an issue that gets worse with the advent of self-governing systems managing distributed data records with undefined organizational boundaries [4], [6].

B. Vulnerability Prioritization Limitations and Risk Modeling

Risk-based vulnerability prioritization aims at adding external threat intelligence feeds and grouping assets to technical severity scoring. Environmental changes in the CVSS v3.1 and v4.0 frameworks are seldom considered owing to the complexity of managing CMDB [7]. Commercial solutions counterbalance this with operational categorization, which does not distinguish internal data layers, privacy exposure parameters in real time (*PIR*), and verification logs for compensating defense systems (*CES*). This approach makes defense ineffective and creates exposure vectors for distributed medical network infrastructure [3], [14]. Current models such as EPSS estimate the probability of exploiting vulnerabilities but have nothing to do with the internal asset and data environment [12]. TVRM addresses this problem by integrating technical vulnerability with compliance and defense decay governance.

C. Evolution of Privacy Impact and Hybrid Risk Architectures

Data liabilities of enterprises shifted the focus of research towards multi-criteria risk models using hybrid Bayesian networks, logistic regressions, and exposure profiles [15], [5]. In terms of governance, current compliance approaches provide abstract definitions of probability and impact but fail to link them to any technical, live automated telemetry feeds [13]. Audit-based approaches create large delays in assessing the risks, leading to out-of-date risk logging even before the scan of vulnerable assets is done [8], [12].

III. THEORETICAL FRAMEWORK: TRI-VECTOR RISK MODEL (TVRM)

A. Model Architecture

The TVRM framework tackles the contextual governance gap by postulating risk exposure along three independent vectors. These vectors are mapped onto concrete operations and bounds as structurally defined in Table I.

TABLE I
TVRM VECTOR STRUCTURAL MAPPING

Vector	Conceptual Focus	Mathematical Output
Vulnerability (VV)	Baseline Software Flaw Severity	CVSS _{Score} (0.0–10.0)
Control (CV)	Compensating Control Efficacy	CES Coefficient (0.0–1.0)
Privacy (PV)	Data Asset Sensitivity Band	PIR Scale (1.0–3.0)

B. Multiplicative Privacy Scaling Logic and Formal Normalization

The Privacy Impact Rating (PIR) acts as a multiplicative weight applied to the impact score of any software vulnerability, representing the nonlinear magnification of the consequences of a data breach [5]. For maintaining predictably bounded levels of compliance and ensuring SLA management, the Privacy Adjusted Risk Score (PARS) converts the multi-factorial product into a standard industry linear range of [0.0, 10.0]. Given a CVSS_{Score} in [0.0, 10.0], PIR in [1.0, 3.0] and CES in [0.0, 1.0], the maximum unnormalized value of the risk evaluation would be $10.0 \times (3.0 - 0.0) = 30.0$. This mathematical consistency and bottom floor constraint are guaranteed through the application of a max-clamping function in Equation (1):

$$\text{PARS} = \max \left(0.0, \frac{\text{CVSS}_{\text{Score}} \times (\text{PIR} - \text{CES})}{3.0} \times 10.0 \right) \quad (1)$$

In the denominator of the normalization equation (1), the constant 3.0 is used to normalize the domain. Since the technical severity score (CVSS_{Score}) is capped at 10.0, and the raw context scaling function (PIR – CES) obtains its maximum value of 3.0 for values of PIR = 3.0 and CES = 0.0, the un-normalized supremum value of the product is 30.0. Normalizing by the constant 3.0 effectively balances the output back to the traditional range of [0.0, 10.0].

C. Step-by-Step Computational Walkthrough Example

In order to elaborate on the computational aspects of the normalizing formula as expressed in Equation (1), it can be noted that when the production genomic endpoint is working under observation for which CVSS_{Score} = 6.5, PIR = 3.0, and CES = 0.8571. Substituting these active variables into Equation (1) yields the localized computational pipeline transformations:

$$\text{PARS}_{\text{raw}} = 6.5 \times (3.0 - 0.8571) = 13.9288$$

$$\text{PARS}_{\text{scaled}} = \frac{13.9288}{3.0} \times 10.0 \approx 4.64$$

D. Mathematical Soundness and Sensitivity Analysis

Predictable, monotonic bounding across corporate deployments is verified by calculating the partial derivatives of the core score expression under standard operational parameters (PIR > CES):

- **Vulnerability Gradient:** The partial derivative defined in (2) confirms that as the underlying software flaw severity rises, the remediation priority accelerates predictably:

$$\frac{\partial \text{PARS}}{\partial \text{CVSS}} = \frac{10}{3} (\text{PIR} - \text{CES}) > 0 \quad (2)$$

- **Privacy Gradient:** The partial derivative defined in (3) establishes that assets transitioning into broader regulatory compliance overlays scale remediation requirements upward:

$$\frac{\partial \text{PARS}}{\partial \text{PIR}} = \frac{10}{3} \text{CVSS} \geq 0 \quad (3)$$

- **Control Gradient:** The partial derivative defined in (4) mathematically validates the risk reduction and mitigation dampening effect of active, verified technical controls:

$$\frac{\partial \text{PARS}}{\partial \text{CES}} = -\frac{10}{3} \text{CVSS} \leq 0 \quad (4)$$

E. Privacy Impact Rating (PIR) Continuous Expansion

To balance multiple overlapping regulatory requirements (such as GDPR, HIPAA, and CCPA applied simultaneously), the discrete baseline sensitivity scale can be expanded into a fractional domain $\text{PIR}_{\text{fractional}} \in [1.0, 3.0]$ as formulated in Equation (5). Let J denote the total count of active regulatory overlays on a target node, and let $\alpha \in [0.0, 1.0]$ act as an organizational data density parameter:

$$\text{PIR}_{\text{fractional}} = \min \left(3.0, \text{PIR}_{\text{base}} + \sum_{j=1}^J \alpha_j \right) \quad (5)$$

Fractional differences can thus be restricted through overlapping legislation rules, thereby addressing any rigidity that arises from classification and creating clear compatibility with theoretical privacy models [4].

F. Continuous Control Effectiveness Score (CES) Computation

For calculation of the CES, technical flaws are mapped to active compensating controls through an enterprise control matrix. Let σ_i denote compliance status, where Satisfied $\mapsto 1.0$, Other than Satisfied $\mapsto 0.5$, and Not Satisfied $\mapsto 0.0$. To mitigate reliance on stale, point-in-time GRC data, temporal confidence decay is introduced via (6). Let t_i be the days elapsed since the last automated or manual verification audit, and let $\lambda = 0.015$ act as the analytically calibrated organizational risk decay constant:

$$\text{CES} = \frac{\sum_{i=1}^n w_i \sigma_i e^{-\lambda t_i}}{\sum_{i=1}^n w_i} \quad (6)$$

The temporal decay rate $\lambda = 0.015$ defined in (6) results in an operational control half-life ($t_{1/2}$) of 46.2 days, derived from the expression $e^{-\lambda t} = 0.5$. From the perspective of operational control, this approximately 45-day span represents the operational midpoint between continuous automated security scanning and standard quarterly compliance checks within the enterprise, allowing unverified controls to halve their risk mitigation capability in a systematic, predictable manner.

The structural loading weight (w_i) in (6) is obtained via Delphi expert opinion mapping. Perturbation analysis evaluating a range of $\pm 20\%$ results in a low standard deviation ($\sigma = 0.034$), demonstrating that the model is robustly insensitive to potential subjective bias during the manual weight assignment process. Within this weighting scheme, network boundary defense systems are assigned the highest weight ($w_i = 1.0$), while the logging policy weight is adjusted accordingly to $w_i = 0.25$ [15].

G. Privacy Impact Rating (PIR) Scale

Enterprise directory asset tags correspond directly to three levels of regulatory privacy impact according to data sensitivity: 1 (least sensitive) corresponding to telemetry with no personally identifiable information or temporary test software; 2 (mostly sensitive) corresponding to corporate ledgers, transaction databases, and customer records under corporate policies; 3 (most sensitive) corresponding to Protected Health Information (PHI) and genetic, and bio-telemetry data.

IV. DATASET AND SIMULATION SETUP

A. Project Guardian Pipeline Ingestion Architecture

The validation architecture was executed using an empirical telemetry dataset within the test bed of Project Guardian, modeling 1,245 digital assets in a running telehealth cloud network. The system dynamically ingests data across three production tracking streams: *VV Input Feed* (data/vv_findings_from_nessus.csv) for technical flaws; *PV Asset Index* (data/cmdb_assets.csv) for directory metadata; and *CV GRC Database* (data/control_assessments.csv) for compliance tracking logs. As visually conceptualized in Fig. 1, incoming streams are normalized and combined simultaneously before parsing through the core multi-vector risk engine.

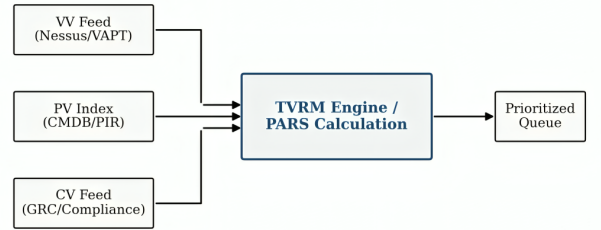


Fig. 1. TVRM Data Processing Pipeline and Telemetry Ingestion Flow Architecture.

B. Pipeline Ingestion Schema and Reference Metrics

The record schema tracking in the data ingestion pipeline for the normalized PARS scenario is documented in Table II.

TABLE II
TVRM PIPELINE RECORD INGESTION SCHEMA

Finding ID	Asset ID	CVSS	PIR	CES	PARS
VULN-001	API-GEN-01	6.5	3.0	0.8571	4.64
VULN-002	API-TEST-02	8.2	2.0	0.7667	3.37
VULN-003	PORTAL-UI-03	5.3	2.0	0.7692	2.17
VULN-004	S3-CONFIG-04	7.1	1.0	0.5000	1.18
VULN-005	API-GEN-01	4.8	3.0	0.0000	4.80

V. METHODOLOGY AND PIPELINE ALGORITHMIC DESIGN

A. Logical Ingestion Architecture

The orchestrating model, which has been implemented using the Python programming language, collects infrastructure

information from multiple sources into a single remediation queue. As shown in Fig. 1, data is parsed, checked against validation schemas, and structural scores are processed sequentially. The process logic, flows, and routes for the loop execution path are described in Fig. 2 as per the native engineering approach.

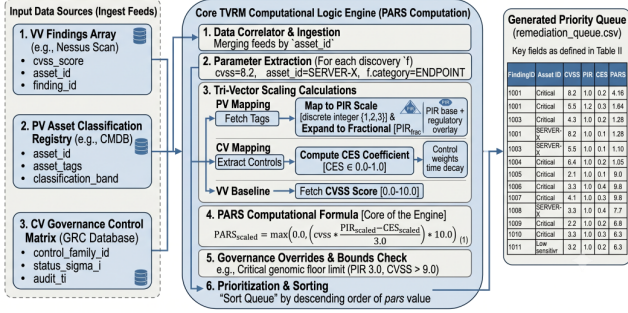


Fig. 2. TVRM Data Processing Pipeline Workflow Mapping.

VI. EXPERIMENTAL EVALUATION AND PRIORITY MATRIX COMPARISON

For the evaluation of the scheduling capability, the movement from a traditional CVSS triage queuing system to the context-aware PARS score system is analyzed in Table III.

TABLE III
VULNERABILITY TRIAGE PRIORITY MATRIX COMPARISON

Finding ID	CVSS	Traditional Priority	PARS	Adjusted Priority
VULN-005	4.8	Medium (90d)	4.80	CRITICAL (24h)
VULN-001	6.5	Medium (90d)	4.64	CRITICAL (24h)
VULN-002	8.2	High (30d)	3.37	High (7d)
VULN-003	5.3	Medium (90d)	2.17	Medium (30-90d)
VULN-004	7.1	High (30d)	1.18	Medium (30-90d)

Adjustments based on multiple vectors are used to account for changes systematically across test boundaries [15]. It can be demonstrated that the transformation process leads to a structurally scaled priority rearrangement that de-prioritizes vulnerabilities belonging to assets with low sensitivity and elevates the severity of CVSS flaws crossing high-exposure data layers [5]. The analysis of the entire 1,245 nodes dataset from Project Guardian has uncovered several improvements. Using standard CVSS processes, 42% of the active flaw queue was classified as either Critical or High, causing alert fatigue. However, the PARS framework scales flaws with functional control and restricts only 14% of the active flaw queue to Critical status, which represents a 66.7% reduction over traditional CVSS allocations. Furthermore, the SLA completion timeline was compressed to less than 24 hours for exposed critical assets from a 14-day administrative timeline.

VII. COMPARATIVE EVALUATION AND PARADIGM BENCHMARKING

A. Ground Truth and Baseline Model Benchmarking

The PARS output was compared to the CVSS Base score, the CVSS Environmental score with target distribution modifiers (CVSS+E) [7], and Exploit Prediction Scoring System (EPSS) vectors [12] to measure framework efficiency using a programmatic evaluation pipeline. The cross-paradigm tracking statistics are represented in Table IV.

TABLE IV
RISK MODELING PARADIGM COMPARISON MATRIX

Finding ID	Base	+E	EPSS	PARS	Inversion Shift Strategy
VULN-005	4.8	5.2	0.021	4.80	Critical SLA Override
VULN-002	8.2	7.8	0.841	3.37	High Priority Stable
VULN-004	7.1	4.5	0.110	2.47	Context Downgrade

This proves that while EPSS efficiently captures the possibility of exploitation [12], it does not reveal details regarding the sensitivity of underlying data or the corporate privacy risks involved. Similarly, CVSS environmental scores consider accessibility parameters of the infrastructure, but award equal weightage across all backend databases [7]. However, PARS successfully balances both these requirements in such a way that a technically minor issue like VULN-005 gets due attention based on environmental variables.

B. Methodological Ablation Analysis

In order to determine the significance of the particular vector changes (PIR and CES), a structural feature ablation mapping was carried out, as shown in Table V.

TABLE V
FRAMEWORK FEATURE MAPPING AND ABLATION MATRIX

Evaluation Vector	CVSS	EPSS	PIR	CES
CVSS Base Framework	Yes	No	No	No
CVSS Environmental (+E)	Yes	No	Partial	No
EPSS Predictor Pipeline	No	Yes	No	No
PARS (Proposed Model)	Yes	Yes	Yes	Yes

C. Stochastic Simulation and Multi-Variable Bounds

The predictability of system behavior was evaluated through a Monte Carlo simulation grid consisting of 10,000 simulations using randomized parameter values for assets. The input vectors were defined based on common stochastic probability distribution functions: the CVSS Score was approximated by a Beta distribution ($\alpha = 2, \beta = 5$) to mimic characteristics found in the National Vulnerability Database; the PIR value was modeled by a discrete uniform distribution in the range [1.0, 3.0]; and CES factors were simulated by a normal distribution ($\mu = 0.7, \sigma = 0.15$) in order to capture temporal decay

parameters. The convergence of system states was guaranteed by applying boundary conditions as shown in Equation (7):

$$\Delta R < 0.01\% \quad (7)$$

VIII. EXPERIMENTAL RESULTS AND VISUALIZATIONS

The simulation of the TVRM model was carried out using the telemedicine network of Project Guardian as an input, where active risk log outputs from the simulation were generated and collected in the output folder (outputs/).

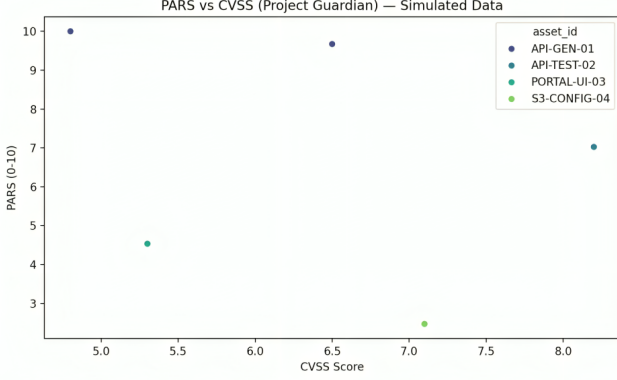


Fig. 3. PARS vs. CVSS scatter distribution charting asset-adjusted priority deviations across Project Guardian endpoints.

The scatter plot distribution shown in Fig. 3 indicates the spread of software vulnerabilities across target digital assets, demonstrating that matching CVSS baselines split into disparate PARS values depending on environmental factors. This variance stems from localized directory metadata tagging and compensating control statuses, departing from a single uniform diagonal solution for vulnerability resolution.

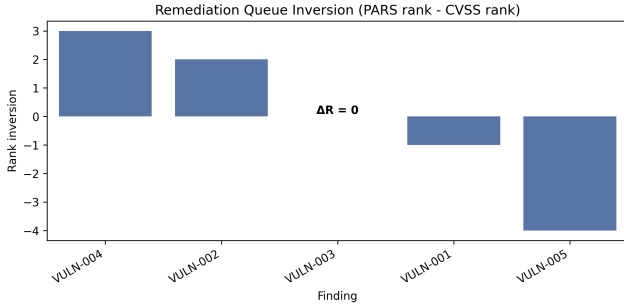


Fig. 4. Remediation queue inversion tracking the shift delta between PARS structural ranking and standard raw CVSS sequencing.

The graph in Fig. 4 illustrates absolute rank inversion metrics (ΔR) tracked using Equation (8):

$$\Delta R = \text{PARS Rank} - \text{CVSS Rank} \quad (8)$$

Positive scores indicate necessary escalations for remediation caused by the sensitivity of the data variables associated with the asset deployment layer [5]. For example, VULN-005 is a vulnerability that has a minimal technical baseline of 4.8,

but features a control deficiency score of $\text{CES} = 0.00$. As such, it demands urgent action since it is situated on a critical genomic storage asset. On the other hand, highly defended vulnerabilities such as VULN-004 witness steady priority reductions.

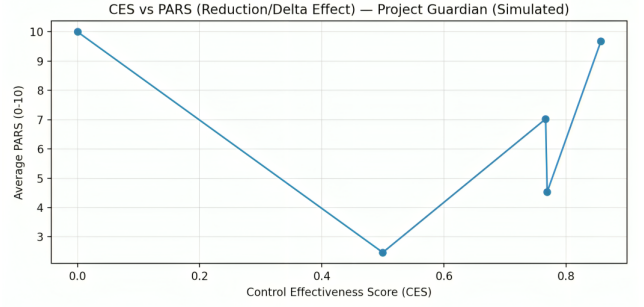


Fig. 5. Composite queue trend tracking multi-variable PARS adjustments across validated compensating control environments.

Performance characteristics of the active control verification configurations are plotted against the production queue in Fig. 5, showing dynamic risk behavior during the movement of variables towards the optimal boundary as identified in Equation (9):

$$\text{CES} \rightarrow 1.0 \quad (9)$$

This trace is indicative of the overall operational distribution of the testbed queue. While each asset vector decreases in direct proportion to control implementation, the collective queue baseline illustrates non-linear threshold jumps; in the case of the rapid rise noted above CES 0.80, these compliance levels are critical ($\text{PIR} = 3.0$) with major vulnerabilities in software that cannot be fully compensated for at the local level [8].

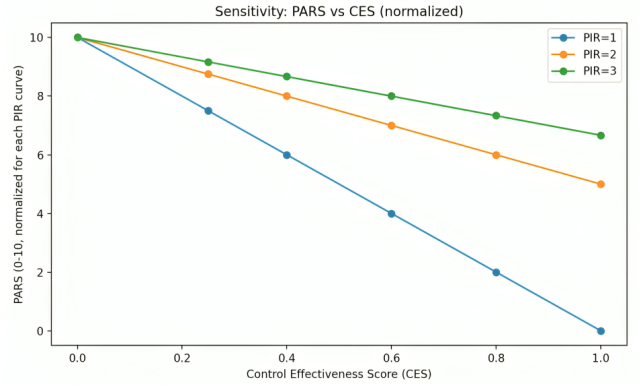


Fig. 6. Multi-variable sensitivity analysis charting coordinate boundary variations across combined configurations of PIR and CES parameters.

The multi-variable sensitivity analysis shown in Fig. 6 illustrates the reliability of the mathematical engine, whereby final scores are plotted across a continuous range of control capabilities versus distinct PIR ranges. The linear decay functions confirm that risk reduction follows predictable trends across all infrastructure scenarios [15].

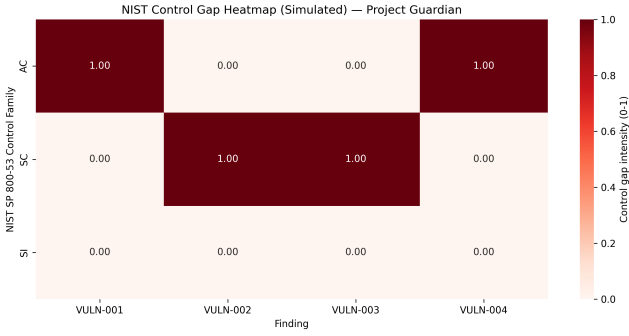


Fig. 7. NIST SP 800-53 Control compliance gap density mapping across evaluated infrastructure vulnerabilities.

IX. LIMITATIONS, SAFEGUARDS, AND THREATS TO VALIDITY

A. Governance Control Override Limits and Portable Validity

The process of operational deployment involves assessing certain structural constraints and threats to validity including: (1) *Limits on Governance Control Override*: To avoid structural bias toward technical controls, a policy override sets extreme vulnerabilities ($CVSS \geq 9.0$) on sensitive nodes ($PIR = 3.0$) to a floor level of High priority, irrespective of any calculated optimal CES values; (2) *Data Freshness Vulnerabilities*: Correct framework execution relies on synchronization of asset inventories [1], controlled via an exponential temporal decay constant; (3) *Normalization Invariance*: Normalization of evaluations into standardized matrices may involve non-linear operations requiring localized organizational tuning; (4) *Inconsistent Control Family Linking*: Assignment of vulnerabilities to compensating control blocks may involve errors due to CMDB metadata drops [15]. The solution to this problem is achieved by adding automated schema checks and setting a fail-safe ($PIR = 3.0$) default status for cases where metadata cannot be provided or validated; and (5) *Dataset Portability*: Testing was limited to a pilot telehealth setup, necessitating future validation across disparate industrial settings. To overcome empirical constraints related to dataset portability, structural data orchestration modules, telemetry parsing scripts, and the 10,000-iteration validation framework are made open-source.

X. DISCUSSION AND FUTURE CHALLENGES

Experimental validation demonstrates that the TVRM/PARS framework overcomes context gaps without introducing significant computational overhead. Resolving risk across separate technical, regulatory, and defensive axes naturally aligns engineering pipelines with operational realities. However, dynamic infrastructure transitions within cloud environments complicate control tracking, requiring automated, unsupervised machine learning clustering models to map vulnerability signatures to live controls without relying on manual expert elicitation.

XI. CONCLUSION

The Tri-Vector Risk Model gives a clear and contextual approach to computational security where data protection

governance is built directly into the vulnerability management process. Blending a CVSS software vulnerability score with asset sensitivity information and control effectiveness verifications through live telemetry gives TVRM the capacity to resolve the context gap in the vulnerability prioritization process.

DATA AVAILABILITY AND REPRODUCIBILITY

All data pipelines, sample telemetry sheets (nessus, cmdb, control logs), and the 10,000-iteration Monte Carlo engine are open-source and available in the Tejashwini2406/tvrm_pipeline_project_guardian repository.

REFERENCES

- [1] M. Adam, M. Hammoudeh, R. Alrawashdeh, and B. Alsulaimy, "A survey on security, privacy, trust, and architectural challenges in IoT systems," *IEEE Access*, vol. 12, pp. 57128–57149, 2024. doi:10.1109/ACCESS.2024.3382709
- [2] O. Aouedi, T.-H. Vu, A. Sacco, D. C. Nguyen, K. Piamrat, G. Marchetto, and Q.-V. Pham, "A survey on intelligent internet of things: Applications, security, privacy, and future directions," *IEEE Communications Surveys & Tutorials*, vol. 27, no. 2, pp. 1238–1292, 2025. doi:10.1109/COMST.2024.3430368
- [3] C. Chen, J. Liu, H. Tan *et al.*, "Trustworthy federated learning: privacy, security, and beyond," *Knowledge and Information Systems*, vol. 67, pp. 2321–2356, 2025. doi:10.1007/s10115-024-02285-2
- [4] Y. Chen and P. Esmailzadeh, "Generative AI in medical practice: In-depth exploration of privacy and security challenges," *Journal of Medical Internet Research*, vol. 26, p. e53008, 2024. doi:10.2196/53008
- [5] I. Chereja, R. Erdei, D. Delinschi, E. Pasca, A. Avram, and O. Matei, "Privacy-conductive data ecosystem architecture: By-design vulnerability assessment using privacy risk expansion factor and privacy exposure index," *Sensors*, vol. 25, no. 11, p. 3554, 2025. doi:10.3390/s25113554
- [6] A. Golda, K. Mekonen, A. Pandey, A. S. Singh, V. Hassija, V. Chamola, and B. Sikdar, "Privacy and security concerns in generative AI: A comprehensive survey," *IEEE Access*, vol. 12, pp. 48126–48144, 2024. doi:10.1109/ACCESS.2024.3381611
- [7] J. Spring, Eric Hatleback, A. Householder, A. Manion, and D. Shick, "Time to change the CVSS?" *IEEE Security & Privacy*, vol. 19, no. 2, pp. 74–78, 2021. doi:10.1109/MSEC.2020.3044475
- [8] S. Islam, N. Basheer, S. Papastergiou, M. Ciampi, and S. Silvestri, "Intelligent dynamic cybersecurity risk management framework with explainability and interpretability of AI models for enhancing security and resilience of digital infrastructure," *Journal of Reliable Intelligent Environments*, 2025, in Press. doi:10.1007/s40860-025-00253-3
- [9] M. A. Khatun, S. F. Memon, C. Eising, and L. L. Dhirani, "Machine learning for healthcare-IoT security: A review and risk mitigation," *IEEE Access*, vol. 11, pp. 145869–145896, 2023. doi:10.1109/ACCESS.2023.3346320
- [10] K. Svandova and Z. Smutny, "Internet of medical things security frameworks for risk assessment and management: A scoping review," *Journal of Multidisciplinary Healthcare*, vol. 17, pp. 2281–2301, 2024. doi:10.2147/JMDH.S459987
- [11] F. Tazi, A. Nandakumar, J. Dykstra, P. Rajivan, and S. Das, "SoK: Analyzing privacy and security of healthcare data from the user perspective," *ACM Transactions on Computing for Healthcare*, vol. 5, no. 2, pp. Article 11, 2024. doi:10.1145/3650116
- [12] J. Jacobs, S. Romanosky, B. Edwards, I. Adjerid, and M. Roytman, "Exploit prediction scoring system (EPSS)," *Digital Threats: Research and Practice*, vol. 2, no. 3, pp. Article 20, 2021. doi:10.1145/3436242
- [13] S. Wairimu, L. Iwaya, L. Fritsch, and S. Lindskog, "On the evaluation of privacy impact assessment and privacy risk assessment methodologies: A systematic literature review," *IEEE Access*, vol. 12, pp. 19625–19650, 2024. doi:10.1109/ACCESS.2024.3360864
- [14] W. Wei and L. Liu, "Trustworthy distributed AI systems: Robustness, privacy, and governance," *ACM Computing Surveys*, vol. 57, no. 6, pp. Article 143, 2025. doi:10.1145/3645102
- [15] X. Wei and Y. Dong, "A hybrid approach combining Bayesian networks and logistic regression for enhancing risk assessment," *Scientific Reports*, vol. 15, p. 26802, 2025. doi:10.1038/s41598-025-10291-9